

# Regex Path Matching Vulnerability due to improper sorting of regex length in corydolphin/flask-cors

✓ Valid

Reported on May 12th 2024

## Description

The plugin prioritize longer regex to provide specificity when matching the path, however, it incorrectly prioritizes longer regex patterns over more specific ones. This can lead to less restrictive CORS policies being applied to sensitive endpoints.

## Proof of Concept

```
from flask import Flask, jsonify
import logging
try:
    from flask_cors import CORS # The typical way to import flask-cors
except ImportError:
    # Path hack allows examples to be run without installation.
    import os
    parentdir = os.path.dirname(os.path.dirname(os.path.abspath(__file__)))
    os.sys.path.insert(0, parentdir)

    from flask_cors import CORS

app = Flask('FlaskCorsAppBasedExample')
logging.basicConfig(level=logging.INFO)

# To enable logging for flask-cors,
logging.getLogger('flask_cors').level = logging.DEBUG

CORS(app, resources={
    r'(/[Aa]pi([Vv][12])?/*)': {'origins': ['*']}, # This match /api, /apiv1,
    r'/api/super_Secret': {'origins': ['https://onlythis.com']}
})

@app.route("/api/super_Secret")
def secret():
    return "Very Confidential. Only serve to https://onlythis.com"

@app.route("/apiv1/users/")
def list_users():
    return jsonify(user="joe")
```

```
if __name__ == "__main__":  
    app.run(debug=True)
```

```
GET /api/super_Secret HTTP/1.1  
Host: 127.0.0.1:5000  
Origin: https://evil.com
```

```
HTTP/1.0 200 OK  
Content-Type: text/html; charset=utf-8  
Content-Length: 53  
Access-Control-Allow-Origin: https://evil.com  
Vary: Origin  
Server: Werkzeug/1.0.1 Python/3.9.5  
Date: Sun, 12 May 2024 14:35:22 GMT  
  
Very Confidential. Only serve to https://onlythis.com
```

## Impact

The mismatch in regex pattern priority allows less restrictive CORS policies to be applied to endpoints that are intended to be highly restricted. This can lead to unauthorized cross-origin access to sensitive data or functionality, potentially exposing confidential information and increasing the risk of unauthorized actions by malicious actors.

## Occurrences

 core.py L73

- ⚙️ We are processing your report and will contact the **corydolphin/flask-cors** team within 24 hours. 2 years ago
- 🕒 A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists 2 years ago
- ⚠️ We were unable to make contact with the **corydolphin/flask-cors** team automatically, our community manager will try to reach out to them instead. 2 years ago
- ✉️ We have sent a magic link to the **corydolphin/flask-cors** team via the email provided in their **security policy** 2 years ago
- ✉️ We have sent a magic link to the **corydolphin/flask-cors** team via the email provided in their **security policy** 2 years ago
- ✉️ We have sent a follow up to the **corydolphin/flask-cors** team. We will try again in 4 days. 2 years ago

✉ We have sent a second follow up to the **corydolphin/flask-cors** team. We will try again in 7 days. 2 years ago

✉ We have sent a third follow up to the **corydolphin/flask-cors** team. We will try again in 14 days. 2 years ago



✎ **Dan McInerney** modified the Severity from High (7.1) to Medium (4.3) 2 years ago



**Dan McInerney** commented 2 years ago

Admin

While that logic can be improved, this is unlikely to impact a large amount of users of the application since it's a specific implementation pattern. I've lowered this to 4.3 to better fit the severity and impact, but @maintainer you are welcome to add thoughts on the score and impact.

✉ We have sent a fourth follow up to the **corydolphin/flask-cors** team. We will send a final notification 48 hours before report publication. 2 years ago



**tomorrowisnew\_** commented 2 years ago

Researcher

How long @admin

★ The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



✓ **Marcello** validated this vulnerability 2 years ago

Marking as valid since we tried contacting the maintainer with no response.

\$ **tomorroisnew** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

🔍 **CVE-2024-6839** assigned to this report. 2 years ago

⚠ We have sent a warning to the **corydolphin/flask-cors** team to inform them that this report will be published in 48 hours a year ago

📡 This vulnerability has now been published a year ago

🔍 **CVE-2024-6839** has now been published 10 months ago

CVE  
CVE-2024-6839  
Published

Vulnerability Type  
CWE-41: Improper Resolution of Path Equivalence

Severity  
Medium (4.3)

|                     |           |
|---------------------|-----------|
| Attack vector       | Network   |
| Attack complexity   | Low       |
| Privileges required | None      |
| User interaction    | Required  |
| Scope               | Unchanged |
| Confidentiality     | Low       |
| Integrity           | None      |
| Availability        | None      |

[Open in visual CVSS calculator](#)

Registry  
Pypi

Affected Version  
4.0.1

Visibility  
Public

Status  
Awaiting fix

Disclosure Bounty  
\$125

Fix Bounty  
\$31.25

Found by



tomorrowisnew\_  
@tomorroisnew  
MIDDLEWEIGHT

